

Enterprise Identity & Access Management

Hybrid Identity · Lifecycle Automation · Access Governance · Zero Trust · ITDR · IGA

- Entra ID
- SailPoint
- PIM
- SCIM
- SAML/OIDC
- CyberArk
-

Hussein Al-Hebshi

Microsoft Security Engineer | Montreal, QC | 2026

DIFFICULTY
ADVANCED

DURATION
16-20 HOURS

How This Lab Is Built

A lifecycle spine, not a feature checklist

Most home labs are a pile of disconnected features. This one is organised the way an identity actually moves through an enterprise: it is born in a system of record, it is provisioned, its access is governed and continuously verified, it is defended when attacked, and eventually it is deprovisioned. Each part builds on the one before it, and every section opens with why it exists, what breaks without it, and how it is run at enterprise scale.

Part	The question it answers	Maps to JD theme
1 — Foundation	Where does identity come from and who owns it?	Hybrid identity, AD, Entra Connect, directory services
2 — Lifecycle (JML)	How does access appear, change, and disappear?	Provisioning/deprovisioning, JML, lifecycle workflows
3 — Access Governance	Who can do what, and can we prove it stayed correct?	RBAC, PIM, entitlement mgmt, access reviews, SoD
4 — Authentication & Zero Trust	How do we verify the identity at runtime?	Conditional Access, MFA, FIDO2/WHfB, SSO (SAML/OIDC)
5 — Identity Threat Detection & Response	What happens when the identity plane is attacked?	MDI, Identity Protection, Sentinel, SOAR playbooks
6 — Enterprise IGA & PAM	How does this scale to 50k users and privileged access?	SailPoint IGA, role mining, SCIM at scale, CyberArk/PAM

The Coverage Promise

This lab is anchored to current IAM job descriptions (Schwab Senior IAM Engineer, Esri IAM Security Engineer, ExxonMobil Entra ID Engineer, and SailPoint-focused roles at FTS Federal and the State of Maryland). The table below maps the most commonly required skills to the section that demonstrates each. If a requirement is conceptual-only because it needs a paid platform, that is stated honestly rather than faked.

Job-description requirement	Where this lab proves it
Entra ID admin, PIM, custom RBAC roles	Part 3 — Sections G1, G2
Conditional Access, Auth Strengths, MFA	Part 4 — Sections Z1, Z2
Passwordless: FIDO2, Windows Hello for Business	Part 4 — Section Z2
SSO integration: SAML / OIDC / OAuth2	Part 4 — Section Z4
Identity Protection, risk policies	Part 5 — Section D2
Microsoft Defender for Identity, XDR signals	Part 5 — Section D1
Sentinel: Log Analytics, Workbooks, Playbooks/SOAR	Part 5 — Sections D3, D4

Entitlement management, access reviews	Part 3 — Sections G3, G4
Segregation of Duties (SoD) controls	Part 3 — Section G5; Part 6 — M3
SCIM provisioning, service principals, federation	Part 2 — L4; Part 4 — Z4
Active Directory: forests, GPO, tiered admin model	Part 1 — F1; Part 3 — G2
JML lifecycle, automated provisioning/deprovisioning	Part 2 — entire part
SailPoint IGA: role mining, certifications, SoD	Part 6 — Sections M1, M2, M3
PAM / CyberArk, privileged access isolation	Part 6 — Section M4
Workday / SAP HR-driven identity	Part 2 — L1 (HR as source of truth)
PowerShell, Microsoft Graph automation	Throughout — every automation step

Lab Environment

Your real infrastructure — build it, don't simulate it

Every identity in this lab originates in Active Directory and flows to the cloud exactly as it would in production. Where a capability genuinely requires a paid external platform (Workday, CyberArk, SAP SuccessFactors), it is marked conceptual — everything else is built hands-on.

Component	Your Lab	Enterprise Equivalent
System of record	HR-simulating CSV + scheduled task	Workday / SAP SuccessFactors
Identity source	simbaloa.local Active Directory (WS2022 DC)	Multi-forest corporate AD
Sync engine	Entra Connect — Password Hash Sync	Entra Connect / Cloud Sync
Cloud directory	Entra ID P2 (M365 E5)	Entra ID P2 at scale
Hybrid endpoint	DESKTOP-3E6497S (Hybrid-joined, Intune)	All corporate devices
ITDR	Microsoft Defender for Identity on the DC	MDI on all DCs + AD FS
SIEM/SOAR	Microsoft Sentinel + Azure Logic Apps	Sentinel / Splunk + SOAR
IGA	SailPoint Identity Security Cloud (dev tenant)	Production SailPoint ISC/IIQ
PAM	Entra PIM (built) + CyberArk (conceptual)	PIM + CyberArk/BeyondTrust

Prerequisites

- M365 E5 tenant (Entra ID P2) — simbaloa.onmicrosoft.com
- Global Administrator in Entra ID; Domain Administrator on simbaloa.local
- Entra Connect installed, Password Hash Sync enabled, syncing OU=EntraID-Users
- Windows Server 2022 DC with the Microsoft Defender for Endpoint sensor active
- Azure subscription with Contributor (for Logic Apps, managed identities)
- Microsoft Sentinel workspace connected to the tenant
- GitHub account (workload identity federation); SailPoint developer tenant
- PowerShell 7+, Microsoft.Graph and ADSync modules

PART 1 — FOUNDATION & SOURCE OF TRUTH

Where identity comes from, who owns it, and how it reaches the cloud

Every access decision later in this lab assumes you know where the identity came from and which system is authoritative for each attribute. Get this wrong and everything downstream inherits the error. So we start at the source.

Section F1 — Hybrid Identity & the Authority Model

AD as system of record · PHS vs PTA vs Federation · attribute ownership

WHY THIS EXISTS:

In a hybrid enterprise the employee identity is not born in the cloud. HR creates it, it lands in Active Directory, and Entra Connect projects it to Entra ID. AD is the system of record for most attributes; the cloud is authoritative for a few cloud-only ones. Knowing which system owns which attribute is the single most important fact in hybrid IAM.

WHAT BREAKS WITHOUT IT:

If you edit a synced attribute in the Entra portal, the next sync cycle overwrites it from AD and your change silently disappears. Teams lose hours to this. Worse, if you assume the cloud is authoritative and build automation on cloud-edited attributes, the automation breaks intermittently and unpredictably.

AT ENTERPRISE SCALE:

Large organisations run multiple AD forests feeding one Entra tenant, with an HR system (Workday/SuccessFactors) as the true source of record above AD. The authority chain is HR -> AD -> Entra ID, and a documented attribute-ownership matrix is a standard audit artifact.

Choosing the Authentication Method — and Defending It

Choosing a hybrid authentication method is a deliberate architecture decision, and you should be able to defend it. The answer is about resilience, threat detection, and operational dependency — not preference.

Method	How auth happens	Security trade-off	Resilience
PHS (this lab)	Password hash-of-hash synced; auth in cloud	Enables leaked-credential detection; hash stored in Entra	High — works if DC is down
PTA	Auth proxied to on-prem agent	Password never leaves on-prem; no leaked-cred detection	Medium — agent dependency
Federation (AD FS)	Entra trusts on-prem AD FS	Full on-prem control; large attack surface; deprecated	Low — AD FS is critical path

TIP

The rationale for this lab: PHS for resilience and security. Cloud authentication keeps working during an on-prem outage, and PHS feeds Entra ID Protection leaked-credential detection — Microsoft compares the synced hashes against breach data. PTA cannot do that because hashes never reach the cloud, and Federation adds a high-value attack surface Microsoft is actively deprecating.

Section F2 — Entra Connect Operations & Attribute Mapping

Verify sync health · document OU scope · map cloud-only lifecycle attributes

WHY THIS EXISTS:

Entra Connect is the bridge. You must be able to verify it is healthy, document exactly which objects it brings to the cloud, and extend it to carry the attributes that drive lifecycle automation — specifically `employeeHireDate` and `employeeLeaveDateTime`, which have no native AD field.

WHAT BREAKS WITHOUT IT:

Without a documented OU scope and attribute map, an incident responder has no baseline: they cannot tell whether a missing user is a sync failure or a deliberate exclusion, and an admin editing the wrong attribute in the wrong place corrupts identities with no audit trail of why.

Step F2.1 — Verify Sync Health & Document Scope

On the Entra Connect server

```
Import-Module ADSync
Get-ADSyncScheduler           # SyncCycleEnabled = True, interval 30 min
Get-ADSyncConnectorRunStatus # RunState should be Idle between cycles
# Document the OU sync scope (audit evidence):
(Get-ADSyncConnector | ? {$_.Type -eq 'AD'}).Partitions |
    Select DN, IncludedContainerNames, ExcludedContainerNames |
    Export-Csv C:\Temp\EntraConnect-OUscope.csv -NoTypeInformation
```

Step F2.2 — Map the Cloud-Only Lifecycle Attributes

`employeeHireDate` and `employeeLeaveDateTime` trigger the joiner and leaver workflows in Part 2. They are cloud-only and cannot be written directly on a synced user via Graph or PowerShell — the only supported path is to store the value in an AD attribute and map it through Entra Connect. This is the foundation the entire lifecycle depends on, so it is built here, once.

WARNING

The AD source value MUST be in Generalized-Time format `yyyyMMddHHmmss.0Z` (e.g. `20260601080000.0Z`). A plain date like `2026-06-01` fails with 'Invalid date time format' at sync. Use `msDS-cloudExtensionAttribute1 / 2` — single-valued strings that exist in the default WS2022 schema, avoiding Exchange schema-prep and multi-value pitfalls.

Store dates in AD (Generalized-Time)

```
Set-ADUser joiner.test -Replace @{msDS-cloudExtensionAttribute1='20260601080000.0Z'}
Set-ADUser leaver.test -Replace @{msDS-cloudExtensionAttribute2='20260615170000.0Z'}
```

Create the inbound sync rule (Synchronization Rules Editor)

```
Start -> Synchronization Rules Editor -> Direction: Inbound
Select 'In from AD - User Common' -> Edit -> Yes (clone; defaults are read-only)
Description tab -> Precedence: 150 (must not collide with an existing rule)
Transformations -> Add transformation (x2), both FlowType = Direct:
```

```
Target: employeeHireDate      Source: msDS-cloudExtensionAttribute1
Target: employeeLeaveDateTime  Source: msDS-cloudExtensionAttribute2
Save (the source-schema warning is expected -> Yes)
# Direct flow works because the AD value is ALREADY in the exact format the
# target expects. Conversion expressions (CDate/FormatDateTime) are the #1 cause
# of failures here and are unnecessary when the source format is correct.
Start-ADSyncSyncCycle -PolicyType Initial    # a NEW rule needs a full sync
```

NOTE

Verify in Metaverse Search (Synchronization Service Manager): the person object should show employeeHireDate populated. If it is in the metaverse but not in Entra ID, the inbound rule is correct and the issue is export — confirm the default 'Out to AAD' rule includes the attribute (it does by default on Entra Connect 2.1.19+).

AT ENTERPRISE SCALE:

In production HR drives this end-to-end: a Workday hire-date field syncs to an AD attribute via the HR connector, Entra Connect maps it to employeeHireDate, and the joiner workflow fires — all with zero human touch. You are building the same pipeline at small scale.

With the source of truth established and the lifecycle-trigger attributes flowing to the cloud, we can now automate what happens across the identity's life: joiner, mover, and leaver.

PART 2 — THE IDENTITY LIFECYCLE (JML)

How access appears on day one, follows role changes, and vanishes on departure

JML is the heart of IAM. Least privilege, privilege creep, the #1 insider-risk of orphaned access — every one of these is really a question about how well you automate this lifecycle. We build all three stages on the foundation from Part 1.

Stage	AD trigger	Cloud automation	Failure mode it prevents
Joiner	Account + hire date	Lifecycle Workflow: license, group, TAP, manager email	New hire idle on day one
Mover	department / title change	Dynamic groups + access-package re-evaluation	Privilege creep
Leaver	leave date / disable	Workflow + SOAR: revoke, strip, notify	Orphaned access (top insider risk)

Section L1 — Joiner: HR Creates, Cloud Provisions

Account born in AD with attributes -> Lifecycle Workflow provisions everything

WHY THIS EXISTS:

A joiner must have the right access before their first day — license, groups, a way to sign in, and a notified manager. In a mature shop this is fully automated off the hire date; nobody opens a ticket. The Lifecycle Workflow is that automation.

WHAT BREAKS WITHOUT IT:

Manual onboarding depends on someone remembering every step. Miss the license and the new hire cannot open email on day one; miss a group and they cannot do their job; forget the manager notification and nobody knows to hand over a laptop. Inconsistent onboarding is both a productivity and a security problem — it is how over-permissioning starts (admins grant broad access 'to be safe').

Step L1.1 — Create the Joiner in AD (complete attributes)

On the DC

```
$mgr = Get-ADUser -Identity 'hazz' # the new hire's manager
New-ADUser `
  -Name 'Joiner Test' -GivenName 'Joiner' -Surname 'Test' `
  -SamAccountName 'joiner.test' `
  -UserPrincipalName 'joiner.test@simbaloa.onmicrosoft.com' `
  -EmailAddress 'joiner.test@simbaloa.onmicrosoft.com' ` # needed for welcome email
  -Department 'IT' -Title 'Security Analyst' `
  -Manager $mgr ` # needed for manager email
  -EmployeeID 'EMP-2026-001' `
  -Path 'OU=EntraID-Users,DC=Simbaloa,DC=local' ` # the SYNCED OU
  -AccountPassword (ConvertTo-SecureString 'P@ssw0rd123!' -AsPlainText -Force) `
  -Enabled $true
Set-ADUser joiner.test -Replace @{msDS-cloudExtensionAttribute1='20260601080000.0Z'}
Start-ADSyncSyncCycle -PolicyType Delta
```

Step L1.2 — Build the Joiner Lifecycle Workflow

entra.microsoft.com -> ID Governance -> Lifecycle workflows -> + New workflow

```
Template: Onboard pre-hire employee
Trigger: employeeHireDate | Days from event: -1 (day before start)
Execution condition: department Equals IT
Tasks:
  Generate Temporary Access Pass (auto-issued – you do NOT create it by hand)
  Send onboarding reminder to manager
  Add user to groups -> SG-IT-Staff
  Assign licenses -> Microsoft 365 E5
Review -> Create
```

TIP

The scheduler evaluates triggers every ~3 hours, so a workflow fires the day before start, not instantly. To demo immediately use Run on demand. Letting it fire automatically and screenshotting Workflow history is stronger evidence — it proves the trigger worked unattended. On MFA: the workflow issues a Temporary Access Pass to solve the bootstrap problem (a new user has no MFA method yet but CA requires MFA). With PHS their AD password already works, so the routine path is password + MFA registration; TAP is for the passwordless/no-method-yet case.

The joiner now has correct day-one access. But people change roles, and the moment they do, yesterday's access becomes tomorrow's audit finding. That is the mover.

Section L2 — Mover: Access Follows the Role

One attribute change -> dynamic groups + access packages re-evaluate automatically

WHY THIS EXISTS:

The mover is the stage most organisations get wrong. They grant the new role's access and forget to remove the old — so people accumulate entitlements from every role they have ever held. Done correctly, the department attribute is the single control: change it, and access leaves the old group/package and joins the new one.

WHAT BREAKS WITHOUT IT:

Privilege creep is the root cause of most access-review findings and a primary lateral-movement enabler. A finance analyst who moved to IT but kept finance access is exactly the over-permissioned account attackers hunt for — and the auditor flags.

AT ENTERPRISE SCALE:

Enterprises combine dynamic groups with entitlement-management auto-assignment and HR-driven attribute changes, so a Workday transfer reshapes access across SharePoint, Teams, and apps within minutes — no ticket, no manual group edits.

Step L2.1 — Build the Dynamic Groups (the engine)

entra.microsoft.com -> Groups -> + New group (Security, Dynamic User)

DYN-IT-Department	rule: (user.department -eq "IT")
DYN-Finance-Department	rule: (user.department -eq "Finance")
DYN-Security-Analysts	rule: (user.jobTitle -contains "Analyst")
# Membership engine re-evaluates within ~5-10 min of an attribute change.	

Step L2.2 — Trigger and Verify the Move

On the DC, then in the portal

```
# Audit trail FIRST – record current memberships:
Get-ADUser mover.test -Properties MemberOf | Select -ExpandProperty MemberOf

# Change in AD (source of truth – never edit the synced attr in the portal):
Set-ADUser mover.test -Department 'IT' -Title 'IT Operations Analyst'
Start-ADSyncSyncCycle -PolicyType Delta

# Verify BOTH directions (this is the part teams forget):
# DYN-IT-Department -> Members -> mover.test PRESENT
# DYN-Finance-Department -> Members -> mover.test ABSENT
```

Access now follows the role automatically. The hardest and highest-risk stage remains: making access disappear completely and immediately when someone leaves.

Section L3 — Leaver: Two Models, Two Purposes

Lifecycle Workflow for scheduled offboarding · SOAR chain for immediate containment

WHY THIS EXISTS:

Leavers are the #1 insider-risk scenario, so the leaver flow answers two different questions and you build both. The Lifecycle Workflow answers 'how do we offboard a planned leaver on their last day, with a clean audit trail?' The Logic App SOAR chain answers 'how do we contain an account RIGHT NOW' — whether that is a planned termination or an analyst killing a compromised account mid-incident.

WHAT BREAKS WITHOUT IT:

Disabling an AD account blocks NEW sign-ins but does NOT kill ACTIVE tokens — Outlook/Teams sessions stay valid up to an hour unless sessions are explicitly revoked. A leaver (or an attacker on their account) keeps working after you think you locked them out. This is why every leaver path revokes sessions, and why Continuous Access Evaluation (Part 4) matters.

	Lifecycle Workflow	Logic App SOAR chain
Trigger	employeeLeaveDateTime reached	Account disabled (any cause), seen in AuditLogs
Timing	Scheduled (up to 3h cycle)	Seconds after the disable event
Best for	Planned, orderly offboarding	Emergency / compromised-account containment
Output	Per-task audit history	Revoke + license strip + alert

Step L3.1 — Model 1: Leaver Lifecycle Workflow

ID Governance -> Lifecycle workflows -> + New workflow

Template: Offboard an employee
Trigger: employeeLeaveDateTime Days from event: 0
Tasks (built-in to the template):
Disable user account
Revoke all sign-in sessions
Remove from all groups
Remove all licenses
Notify manager
Review -> Create (test with Run on demand -> leaver.test)

Step L3.2 — Model 2: SOAR Containment Chain

A scheduled PowerShell task on the DC disables the AD account on the termination date (simulating the HR feed). Entra Connect syncs the disabled state. A Sentinel rule detects it and triggers a Logic App that revokes sessions and strips licenses in seconds. The same chain fires when an analyst disables an account during an incident — which is its real value.

Step	Where	Action
1	DC scheduled task	Reads terminations.csv, disables AD account on the date

2	Entra Connect	Syncs disabled state to Entra ID
3	Sentinel rule	Detects AccountEnabled -> false in AuditLogs
4	Logic App (MI)	Revoke sessions, remove licenses, email manager

Sentinel — detection rule

```
AuditLogs
| where TimeGenerated > ago(1h)
| where OperationName in ('Disable account','Update user')
| mv-expand TargetResources
| mv-expand props = TargetResources.modifiedProperties
| where tostring(props.displayName) == 'AccountEnabled'
| where tostring(props.newValue) has 'false'
| extend DisabledUser = tostring(TargetResources.userPrincipalName)
| project TimeGenerated, DisabledUser
# Run every 5 min | Entity: Account -> DisabledUser
```

Logic App — containment playbook (system-assigned managed identity)

```
TRIGGER Microsoft Sentinel alert
ACTION1 POST .../users/{upn}/revokeSignInSessions
ACTION2 GET .../users/{upn}?$select=assignedLicenses
ACTION3 POST .../users/{upn}/assignLicense (removeLicenses = all returned)
ACTION4 POST .../users/{manager}/sendMail (offboarding notice)
# MI Graph permissions: User.ReadWrite.All, Mail.Send
```

AT ENTERPRISE SCALE:

In production the leaver workflow is triggered straight from the HR termination record — a Friday-afternoon termination fires the whole chain with no IT action and no access left live over the weekend. The SOAR chain runs in parallel as the immediate-containment safety net that does not wait for the scheduler.

Lifecycle automation decides what access an identity gets. The next question every IAM JD asks is governance: is that access correct, least-privilege, and provably reviewed over time?

PART 3 — ACCESS GOVERNANCE

Who can do what — least privilege, privileged access, and provable controls

Lifecycle automation grants access; governance proves that access is correct and stays correct. This is where JDs concentrate: RBAC design, PIM, entitlement management, access reviews, and Segregation of Duties.

Section G1 — RBAC: Three Models, Least Privilege

Entra roles vs Azure RBAC vs app roles · admin units · scoped delegation

WHY THIS EXISTS:

RBAC sounds simple until you realise Microsoft has three separate, non-overlapping RBAC systems. Conflating them is one of the most common points of confusion in Azure security and a real source of over-privilege.

WHAT BREAKS WITHOUT IT:

Grant Contributor when someone needed 'start a VM' and they can now rewrite networking and storage. Grant User Administrator when someone needed 'reset passwords' and they can now modify every account including admins. Over-privilege is the path from initial access to domain compromise.

System	Controls	Assigned in	Example
Entra ID roles	Identity management plane	Roles & admins	Password Admin, Security Reader
Azure RBAC	Azure resources	Resource IAM	VM Contributor, Key Vault Secrets User
App roles	Features inside one app	Enterprise app -> App roles	Approver, Helpdesk

NOTE

Key fact: a Global Admin in Entra ID has ZERO access to Azure resources unless separately granted an Azure RBAC role. The two are fully separate control planes.

Step G1.1 — Scope a Helpdesk Role with an Administrative Unit

WHY THIS EXISTS:

Without scoping, a Password Administrator can reset ANY password — including Global Admins, which is a privilege-escalation path. An Administrative Unit scopes the role to a subset of users.

entra.microsoft.com -> Administrative units

+ Add -> Name: AU-StandardUsers -> Membership: Assigned (or dynamic)

Add members: standard user accounts only (no admins)

AU-StandardUsers -> Roles and administrators -> + Add assignment

Role: Password Administrator -> assign to helpdesk user

Result: helpdesk can reset passwords ONLY for AU-StandardUsers,

never for Global Admins. Test both outcomes for portfolio evidence.

Scoping standard roles is half the picture. The accounts that actually matter are the privileged ones — and they need a fundamentally stronger model.

Section G2 — Privileged Access: PIM & the Tiered Model

Just-in-time elevation · approval · tiered administration · break-glass

WHY THIS EXISTS:

Standing privileged access is the biggest risk in any directory. PIM makes privilege just-in-time: an admin is ELIGIBLE for a role but holds it only for an approved, time-boxed, justified, logged window. Combined with the tiered admin model (named explicitly in senior JDs), it isolates the credentials that can destroy the environment.

WHAT BREAKS WITHOUT IT:

If ten people hold permanent Global Admin, you have ten always-on keys to the kingdom — any one phished account is game over, and an auditor will fail you. Standing privilege also means a compromised admin token grants instant full control with no approval friction.

AT ENTERPRISE SCALE:

Mature orgs run a tiered model: Tier 0 (identity/domain controllers) admins never sign in to Tier 1/2 systems, separate admin accounts per tier, and PIM gating every elevation. CyberArk (Part 6) vaults the Tier 0 credentials on top.

Step G2.1 — Make Global Admin Eligible (not permanent)

entra.microsoft.com -> ID Governance -> PIM -> Entra roles

Roles -> Global Administrator -> Assignments -> + Add (Eligible, not Active)

Role settings -> Edit:

Activation max duration: 2 hours

Require justification on activation: Yes

Require approval: Yes -> approver: a second admin

Require MFA on activation: Yes (ideally phishing-resistant — see Z2)

Now nobody HOLDS Global Admin; they activate it, justified and logged.

WARNING

Break-glass: keep two cloud-only emergency accounts EXCLUDED from PIM and Conditional Access, with long stored passwords and alerting on any sign-in. They are your recovery path if PIM or CA misconfiguration locks everyone out.

PIM governs the privileged few. Entitlement management governs access for everyone else — at request-and-approve scale.

Section G3 — Entitlement Management: Access Packages

Bundled access · self-service request · approval · auto-assignment · expiry

WHY THIS EXISTS:

An access package bundles the groups, apps, and roles a job function needs into one requestable unit with built-in approval, expiry, and review. It turns 'email IT for access' into governed self-service, and it is the mover engine's governance layer.

WHAT BREAKS WITHOUT IT:

Without packaged access, entitlements are granted ad hoc and individually — impossible to review, impossible to revoke cleanly, and the source of the sprawl that makes access certifications meaningless.

ID Governance -> Entitlement management

Catalogs -> + New catalog: IT-Security-Resources
Add resources: SG-IT-Staff, SG-Sentinel-Readers, target apps
Access packages -> + New: IT-Security-Analyst-Access
Resource roles: the groups above -> Member
Request policy: approval required -> approver = manager; expire after 365 days; review on
Auto-assignment policy: department Equals IT -> assign;
when filter no longer matches -> REMOVE access (auto-revoke on transfer)
Test: myaccess.microsoft.com -> request -> approve -> verify membership.

Granting and bundling access is one half of governance. The other half is proving, on a schedule, that it is still correct.

Section G4 — Access Reviews: Prove It Stayed Correct

Recurring recertification · fail-secure defaults · guest governance

WHY THIS EXISTS:

Access reviews are the recurring proof auditors demand: on a schedule, an accountable owner confirms each person still needs their access. Fail-secure means no-response defaults to removal, not retention.

WHAT BREAKS WITHOUT IT:

Without reviews, access only ever accumulates. The classic finding is the contractor invited for a 2-week project who still has access two years later. Reviews are the control that catches exactly that.

ID Governance -> Access reviews -> + New

Privileged roles (monthly):
Scope: PIM-eligible Global/Security Admins Reviewer: security team Monthly
Guest access (quarterly, fail-secure):
Type: Teams + Groups Scope: Guest users only Reviewer: group owners
If reviewers don't respond: REMOVE access <- fail-secure
Auto-apply: Yes Require reason: Yes

Guest lifecycle (the moved-in-2026 setting)

Guest account removal is now under ID Governance, not External collaboration

ID Governance -> Control configurations -> Lifecycle of external users -> Edit
Remove external user: Yes
Block sign-in then remove after: 30 days (90 for lower churn)
Complementary, separate control: SharePoint admin center -> Policies -> Sharing
expires guest access to SITES/links; the above removes the directory ACCOUNT.

Reviews confirm access is correct. But 'correct' also means no single person holds a toxic COMBINATION of access — that is Segregation of Duties.

Section G5 — Segregation of Duties (SoD)

Preventing toxic access combinations · the control auditors live for

WHY THIS EXISTS:

SoD prevents one person from holding access that, combined, lets them commit and conceal fraud — the canonical example being someone who can both CREATE a vendor/payment AND APPROVE it. It is a named requirement in SOX, PCI, and most IGA job descriptions, and it is about combinations, not individual entitlements.

WHAT BREAKS WITHOUT IT:

Without SoD enforcement, a single insider (or a single compromised account) can execute and hide a fraudulent transaction end-to-end. This is the control financial auditors test first, and its absence is a material audit finding.

AT ENTERPRISE SCALE:

Native Entra entitlement management enforces a basic form: an access package can be configured as incompatible with another, so requesting one blocks the other. True enterprise SoD — hundreds of conflict rules mined across hundreds of apps — is what dedicated IGA platforms like SailPoint exist for (Part 6, M3).

Step G5.1 — Enforce an Incompatible-Access Rule in Entra

ID Governance -> Entitlement management -> Access packages

```
# Define two packages that must never be held together, e.g.:
#   AP-Vendor-Create      (can create vendor/payment records)
#   AP-Payment-Approve    (can approve payments)
Open AP-Payment-Approve -> Separation of duties / Incompatible access packages
  + Add incompatible access package -> AP-Vendor-Create
# Result: a user assigned AP-Vendor-Create is BLOCKED from requesting
# AP-Payment-Approve (and vice-versa). The toxic combination is prevented
# at request time rather than caught months later in an audit.
```

TIP

The two layers: Entra enforces SoD as incompatible access packages, which covers Microsoft-resident access. For cross-application SoD — say a conflict between an SAP role and a Salesforce role — you need an IGA platform like SailPoint that aggregates entitlements across all systems and evaluates policy globally. This lab builds both.

Governance defines who SHOULD have access. Authentication enforces, at every sign-in, that the person using it is really them — Zero Trust.

PART 4 — AUTHENTICATION & ZERO TRUST

Verifying the identity at runtime — Conditional Access, passwordless, SSO

Governance decides what access exists; authentication enforces, at every sign-in, that the right person is using it under the right conditions. This is the runtime enforcement layer of Zero Trust.

Section Z1 — Conditional Access: The Policy Engine

Signals -> decision -> enforcement · the heart of Zero Trust

WHY THIS EXISTS:

Conditional Access is the Zero Trust decision engine. Every sign-in is evaluated against signals (user, device, location, app, risk) and granted, blocked, or challenged. Authentication Methods Policy decides what's ALLOWED; CA decides when MFA or compliance is REQUIRED.

WHAT BREAKS WITHOUT IT:

Without CA, MFA is all-or-nothing and there is no way to require a compliant device for sensitive apps or block legacy protocols. Legacy auth (which bypasses MFA entirely) remains the most common initial-access vector — CA is how you kill it.

entra.microsoft.com -> Protection -> Conditional Access

```
# Baseline set every tenant should have (build in Report-only first):
```

```
CA001 Require MFA for all users (exclude break-glass)
```

```
CA002 Block legacy authentication (no modern auth = no access)
```

```
CA003 Require compliant or Hybrid-joined device for M365 apps
```

```
CA004 Require phishing-resistant MFA for admin roles (see Z2)
```

```
# Always exclude SG-BreakGlass-Exclude; always stage in Report-only.
```

CA decides *WHEN* to challenge. The strength of that challenge — whether it can be phished — is the next decision.

Section Z2 — Passwordless & Phishing-Resistant Auth

FIDO2 · Windows Hello for Business · Authentication Strengths · Token Protection · CAE

WHY THIS EXISTS:

Standard push MFA proves a second factor happened — but an adversary-in-the-middle proxy (Evilginx) relays the prompt and steals the resulting token. FIDO2 and Windows Hello for Business are cryptographically bound to the device and cannot be phished this way. Authentication Strengths let CA require specifically these methods for sensitive roles.

WHAT BREAKS WITHOUT IT:

If admins authenticate with phishable push MFA, a single AiTM phishing page harvests an admin token and your strongest accounts fall — MFA notwithstanding. This is now one of the most common real-world breach patterns.

Authentication Strengths + Token Protection + CAE

```
# Phishing-resistant strength for admins:
```

```
CA -> Authentication strengths -> + New: PhishingResistant-AdminsOnly
```

```
  Allow: FIDO2 security key, Windows Hello for Business  (uncheck push/SMS/voice)
```

```
Attach to CA004 -> Grant: Require authentication strength -> PhishingResistant-AdminsOnly
```

```
# Token Protection (binds token to the device it was issued on):
```

```
CA policy -> Session -> Token protection -> Enabled (Report-only first; breaks legacy)
```

```
# Continuous Access Evaluation (near-real-time revocation):
```

```
CA -> Continuous access evaluation -> Enabled (default for Exchange/SharePoint/Teams)
```

```
# Test: revoke a signed-in user's sessions -> Outlook errors within ~60s (vs up to 1h).
```

AT ENTERPRISE SCALE:

CAE is what makes the Part 2 leaver flow actually immediate: without it, a disabled account's live tokens linger up to an hour; with it, revocation propagates in seconds. Passwordless rollout for the whole workforce (not just admins) is the current enterprise direction.

CA and strong auth protect interactive sign-ins. Identity Protection adds the risk intelligence that feeds those policies — covered in Part 5.

Section Z3 — App Registrations, Service Principals & OAuth

Delegated vs application permissions · consent · illicit-consent attacks

WHY THIS EXISTS:

Every app that authenticates to your tenant has an identity: an app registration (the blueprint) and a service principal / enterprise app (the instance). Their OAuth permissions are an attack surface — delegated permissions act as the signed-in user; application permissions act as the app itself, tenant-wide, admin-consent only.

WHAT BREAKS WITHOUT IT:

Illicit consent grant attacks trick a user or admin into approving a malicious app with Mail.ReadWrite or Files.ReadWrite.All — giving an attacker standing access to all mail or files with no password ever stolen and nothing for MFA to catch. Knowing how to find and revoke these grants is a core IAM skill.

entra.microsoft.com -> App registrations / Enterprise applications

```
# Build a registration (the legitimate pattern):
+ New registration: Lab-SecurityApp | Single tenant | Redirect: http://localhost
API permissions -> Microsoft Graph:
  Delegated: User.Read, AuditLog.Read.All
  Application: SecurityEvents.Read.All (admin consent required)
Certificates & secrets -> prefer a certificate or federated credential over a secret
# Audit existing consents (the defensive half):
Enterprise applications -> filter Third-party -> each app -> Permissions
  Flag: Mail.ReadWrite, Files.ReadWrite.All, Directory.ReadWrite.All (Application)
  Revoke suspicious: Permissions -> Revoke admin consent
```

Internal apps authenticate via registrations. External and SaaS apps authenticate via federation protocols — SAML and OIDC — the SSO backbone every JD lists.

Section Z4 — SSO Federation: SAML, OIDC & SCIM

The protocols behind every 'sign in with' button — and how to integrate one

WHY THIS EXISTS:

SSO means one identity authenticates to many apps. The protocols are SAML (XML-based, mature, enterprise SaaS) and OIDC/OAuth2 (JSON/JWT, modern, mobile and API friendly). Entra ID is the Identity Provider (IdP); the app is the Service Provider / Relying Party. SCIM then keeps user accounts provisioned in that app automatically. Every IAM JD lists SAML/OIDC/SCIM by name.

WHAT BREAKS WITHOUT IT:

Without SSO, every app has its own password — the user reuses one weak password everywhere and there is no central MFA or revocation. Disable the leaver in Entra and their twelve SaaS accounts still work. SSO + SCIM is what makes central identity actually central.

	SAML 2.0	OIDC / OAuth2
Token	XML assertion	JSON Web Token (JWT)
Best fit	Enterprise SaaS (legacy + current)	Modern web, mobile, APIs
Flow	Redirect + POST assertion	Authorization code + token exchange
Entra role	Identity Provider (IdP)	Identity Provider / Authorization Server

Step Z4.1 — Configure SAML SSO + SCIM to a Gallery App

Enterprise applications -> + New application (e.g. Salesforce/Slack gallery)

SSO (SAML):

Single sign-on -> SAML

Identifier (Entity ID) and Reply (ACS) URL: from the app's admin console

Attributes & Claims: map user.userprincipalname -> NameID, plus email/role claims

Download Entra's Federation Metadata XML -> upload to the app

Assign users/groups -> the app now honours Entra MFA + Conditional Access

SCIM (automatic provisioning, so accounts follow the lifecycle):

Provisioning -> Automatic -> Admin Credentials: SCIM endpoint + bearer token

Test Connection -> Mappings: userPrincipalName->userName, mail, displayName, dept

Scope: assigned users/groups -> Start provisioning

Now: create in Entra -> account appears in the app; disable -> app account

deactivates within a sync cycle. SSO authenticates; SCIM provisions.

AT ENTERPRISE SCALE:

Enterprises connect 50-200 SaaS apps this way. SCIM closes the leaver gap across the entire SaaS estate — without it, deprovisioning is a manual checklist no one completes, and that gap is a top audit and breach risk.

Authentication and federation protect the front door. When attackers get past it — or attack the directory itself — you need detection and response on the identity plane.

PART 5 — IDENTITY THREAT DETECTION & RESPONSE (ITDR)

When the identity plane is attacked — detect on-prem and cloud, respond automatically

Prevention fails eventually. ITDR is the assumption-of-breach layer: detect attacks against AD and Entra ID, and respond fast enough to matter. Every Microsoft IAM JD lists MDI, Identity Protection, and Sentinel SOAR.

Section D1 — Defender for Identity & AD Attacks

Sensor on the DC · Kerberoasting · LDAP recon · DCSync · honeytokens

WHY THIS EXISTS:

Microsoft Defender for Identity puts a sensor on the domain controller and watches authentication and directory traffic for attack patterns the Windows event log alone misses. These are attacks against the identity plane itself — which is why ITDR belongs in an IAM lab, not just a generic SOC one.

WHAT BREAKS WITHOUT IT:

Without DC-level identity detection, Kerberoasting and DCSync look like normal traffic. DCSync in particular lets an attacker replicate every password hash including krbtgt — enabling Golden Tickets and total domain forgery — and you would never see it in basic logging.

Step D1.1 — Activate the Sensor & Plant a Honeytoken

security.microsoft.com -> Settings -> Identities

```
Sensors -> + Add sensor (or activate via the MDE-onboarded DC) -> confirm Running
Entity tags -> Sensitive: tag Domain/Global Admin accounts
Entity tags -> Honeytokens: tag a deliberately unused account (e.g. it.admin.old)
# Any authentication to a honeytokens = high-fidelity 'attacker is here' alert.
```

Step D1.2 — Simulate Three Identity Attacks

Kerberoasting — steal a service-account credential offline

```
# A service account with an SPN can be Kerberoasted by ANY domain user:
Set-ADUser svc-sql -ServicePrincipalNames @{Add='MSSQLSvc/sql.simbaloa.local:1433'}
Add-Type -AssemblyName System.IdentityModel
New-Object System.IdentityModel.Tokens.KerberosRequestorSecurityToken `
  -ArgumentList 'MSSQLSvc/sql.simbaloa.local:1433'
# MDI alert: 'Suspected Kerberos SPN exposure' (unusual RC4 ticket request).
```

LDAP reconnaissance — map the directory

```
Get-ADUser -Filter * -Properties *; Get-ADGroupMember 'Domain Admins' -Recursive
# MDI alert: 'Reconnaissance using directory services queries'.
```

DCSync — replicate password hashes (the crown-jewel attack)

```
$dc = $env:LOGONSERVER.TrimStart('\')
$s = New-PSSession -ComputerName $dc
Invoke-Command -Session $s { Get-ADUser krbtgt -Properties PasswordLastSet }
Remove-PSSession $s
# MDI alert: 'Suspected DCSync attack' — CRITICAL. Response: isolate source,
# disable the account, then reset krbtgt TWICE to invalidate all tickets.
```

MDI covers attacks on on-prem AD. Identity Protection covers the cloud side — compromised credentials and risky sign-ins in Entra ID.

Section D2 — Identity Protection: Risk-Based Defense

Sign-in risk vs user risk · self-service remediation · feeding Conditional Access

WHY THIS EXISTS:

Identity Protection scores risk from Microsoft's signal graph: sign-in risk (is THIS login suspicious — impossible travel, anonymous IP) and user risk (is this ACCOUNT likely compromised — leaked credentials). Policies then auto-remediate, mostly without an analyst.

WHAT BREAKS WITHOUT IT:

Without risk-based policy you treat every login identically — either annoying everyone with constant MFA or missing the genuinely compromised account. Risk scoring is what lets you challenge only when it matters.

entra.microsoft.com -> Protection -> Identity Protection

Sign-in risk policy: Medium+ -> Require MFA (self-service, no analyst)
User risk policy: High -> Require secure password change
Exclude: SG-BreakGlass-Exclude Enforce: On
These handle the BULK of standard users automatically. The escalation
path for PRIVILEGED accounts is the SOAR playbook in D4.

Risk signals are only useful if you can hunt and respond across them. Sentinel is where on-prem (MDI), cloud (Identity Protection), and everything else converge.

Section D3 — Sentinel: Unified Identity Detection

Connect DC events + Entra logs · KQL detections · workbooks

WHY THIS EXISTS:

Sentinel is the SIEM where identity signals from everywhere — DC security events, Entra sign-in and audit logs, MDI, Identity Protection — land in one place for correlation, KQL hunting, and automated response. JDs name Log Analytics, Workbooks, and Playbooks specifically.

WHAT BREAKS WITHOUT IT:

Siloed signals miss the chain. A failed-then-successful admin sign-in in Entra plus a DCSync alert in MDI is obviously one attack — but only if they sit in the same SIEM. Apart, each looks like noise.

Sentinel -> Logs — high-value identity KQL

```
// Privileged group changes on-prem (4728/4732/4756):
SecurityEvent | where EventID in (4728,4732,4756)
| where TargetUserName has_any ('Domain Admins','Enterprise Admins')
// Honeytoken authentication = attacker present (any result is critical):
SecurityEvent | where EventID in (4624,4625,4768,4769)
| where AccountName =~ 'it.admin.old'
// Risky sign-in correlated to a privileged role (cross-source):
AADUserRiskEvents | where RiskLevel == 'high' and RiskState == 'atRisk'
| join kind=inner (IdentityInfo | where AssignedRoles has 'Admin'
| project AccountUPN, AssignedRoles) on $left.UserPrincipalName==$right.AccountUPN
```

Detection without response is just an alert nobody actions at 3am. The final ITDR layer turns a detection into automatic containment.

Section D4 — SOAR: Automated Containment

Sentinel rule -> Logic App -> contain a high-risk privileged account in seconds

WHY THIS EXISTS:

SOAR converts a detection into action without waiting for a human. The key design decision: self-service remediation (D2) handles standard users; the SOAR playbook is reserved for PRIVILEGED accounts, where the correct response is disable-and-investigate, not let-them-reset.

WHAT BREAKS WITHOUT IT:

A high-risk Global Admin at 3am cannot wait for an analyst to wake up. Without automated containment, the window between detection and response is exactly the window an attacker uses to establish persistence.

NOTE

Scoping correction most people miss: target USER risk (AADUserRiskEvents), not sign-in risk, and JOIN to IdentityInfo so ONLY admin-role holders match. Otherwise the playbook would disable every high-risk standard user and override the gentler self-service policy.

Sentinel rule + Logic App (system-assigned managed identity)

Rule: IdentityProtection-HighRiskAdmin-AutoContain (the D3 join query) | every 15 min

Entity mapping: Account -> UserPrincipalName

Logic App la-highrisk-admin-contain:

TRIGGER Sentinel alert

ACTION1 POST .../users/{upn}/revokeSignInSessions

ACTION2 PATCH .../users/{upn} {"accountEnabled": false}

ACTION3 POST .../users/{soc}/sendMail (HIGH RISK ADMIN CONTAINED)

MI Graph permissions: User.ReadWrite.All, Mail.Send

Attach: rule -> Automated response -> la-highrisk-admin-contain

AT ENTERPRISE SCALE:

Production SOAR enriches before acting (geo-IP, recent travel, manager lookup), opens a ServiceNow incident, and pages on-call — the whole chain inside ~90 seconds of the risk signal, every time, with no analyst awake.

Everything so far is buildable on Microsoft tooling. The last part is what separates senior IAM candidates: governing identity at 50,000-user scale and across non-Microsoft systems.

PART 6 — ENTERPRISE IGA & PRIVILEGED ACCESS

Scaling identity governance beyond Microsoft — SailPoint, SCIM at scale, PAM

Entra ID Governance is excellent for the Microsoft estate. But enterprises run hundreds of non-Microsoft systems, and the JDs that pay the most ask for SailPoint, cross-application SoD, and privileged access management. This part gives those equal weight to the Microsoft stack.

Section M1 — Why a Dedicated IGA Platform Exists

What SailPoint does that Entra cannot · connect a source · aggregate identities

WHY THIS EXISTS:

Entra governs identities IT already knows about, in SCIM-connected apps. A dedicated IGA platform (SailPoint Identity Security Cloud / IdentityIQ) aggregates identity and entitlement data from EVERYTHING — AD, SAP, Oracle, mainframe, Salesforce, 200+ connectors — into one governance model, then mines roles, enforces cross-app SoD, and runs certification campaigns across the whole estate.

WHAT BREAKS WITHOUT IT:

Without an IGA platform, governance stops at the Microsoft boundary. The SAP and Oracle entitlements — usually the ones that matter most for financial fraud — are ungoverned, unreviewed, and invisible to your access certifications.

Capability	SailPoint IGA	Entra ID native
Source breadth	200+ connectors (SAP, Oracle, mainframe...)	Entra + SCIM apps only
Role mining	ML suggests roles from real access patterns	Not available
Cross-app SoD	Policy across all connected systems	Incompatible packages only
Certification scale	50k users, 200 apps, one campaign	M365 groups + PIM roles

developer.sailpoint.com — free dev tenant; connect a source

```
Register -> tenant: [you]-sb.identitynow.com
Admin -> Connections -> Sources -> + Add -> Delimited File (CSV)
  Upload identities.csv (id,firstName,lastName,email,department,manager)
  Map: id->Account ID, email->Email, etc. -> Save
Source -> Aggregate -> identities appear in the Identities list
# This is the foundation: SailPoint now has an authoritative identity warehouse.
```

Section M2 — Role Engineering & Access Certification

Role mining · birthright vs requestable roles · certification campaigns

WHY THIS EXISTS:

Role engineering turns chaotic individual entitlements into managed roles. Role mining analyses who actually has what and suggests roles from the patterns — e.g. 'every IT analyst shares these 6 entitlements, make that a role.' Certifications then have managers/owners recertify access on a schedule. Both are named SailPoint JD requirements.

WHAT BREAKS WITHOUT IT:

Without role engineering you govern thousands of individual grants one by one — certifications become a meaningless rubber-stamp because no reviewer can reason about 4,000 raw entitlements. Roles make access reviewable in human terms.

AT ENTERPRISE SCALE:

A birthright role is auto-granted by attribute (every employee gets email + intranet); a requestable role goes through approval (the finance-reporting role). Mining typically cuts an organisation's entitlement count by an order of magnitude.

SailPoint — certification campaign

Admin -> Certifications -> + Create Campaign
Type: Manager Scope: all identities in Lab-CSV-Source Deadline: 14 days
Generate -> Activate
Access certifications -> Pending reviews -> Approve / Revoke each
Results -> revocations flow back to the connected source as deprovisioning actions
At scale this runs monthly for privileged, quarterly for standard, tracked as a KPI.

Section M3 — Cross-Application Segregation of Duties

Where SoD graduates from Entra incompatible-packages to true policy enforcement

WHY THIS EXISTS:

Part 3 enforced SoD between two Entra access packages. Real SoD is cross-application: the conflict is between an SAP 'create vendor' entitlement and an Oracle 'approve payment' entitlement — different systems entirely. Only a platform that aggregates entitlements from both can evaluate that policy. This is the single biggest reason regulated enterprises buy SailPoint.

WHAT BREAKS WITHOUT IT:

A SoX-regulated company that cannot enforce cross-system SoD has a material weakness in its financial controls — a finding that lands in the annual report and the auditor's letter to the board. This is not abstract; it is why the budget exists.

SailPoint — define and enforce an SoD policy

Admin -> Policies -> + New Policy -> Separation of Duties
Left set: entitlement 'SAP_Vendor_Create'
Right set: entitlement 'Oracle_Payment_Approve'
Violation: a single identity holding BOTH
Action: alert + require mitigating control, or auto-revoke on certification
Run policy scan -> violations surface on the identity and in the next campaign
This is the capability Entra cannot provide and the reason IGA platforms exist.

Section M4 — Workload Identity & Privileged Access Management

OIDC federation for CI/CD (no secrets) · Entra PIM mapped to CyberArk

WHY THIS EXISTS:

Two senior topics close the lab. Workload identity federation removes stored secrets from CI/CD: GitHub Actions presents a signed OIDC token Entra trusts, exchanged for an Azure token — nothing to leak or rotate. PAM (CyberArk) extends privileged governance beyond Entra to servers, databases, and network gear that PIM cannot reach.

WHAT BREAKS WITHOUT IT:

Stored CI/CD client secrets get committed to repos, leak, and expire mid-deploy — a perennial breach source. And PIM alone leaves on-prem root/DBA/network credentials ungoverned: no vaulting, no session recording, no rotation on the systems attackers most want.

Step M4.1 — Workload Identity Federation (build it)

App registration -> Certificates & secrets -> Federated credentials

Scenario: GitHub Actions deploying Azure resources
Org/repo: <you>/iam-lab Branch: main
Grant the app an Azure RBAC role (e.g. Reader) on the subscription
GitHub repo secrets: AZURE_CLIENT_ID, AZURE_TENANT_ID, AZURE_SUBSCRIPTION_ID (IDs only)
Workflow uses azure/login@v2 with id-token: write -> az account show succeeds
Zero stored credentials. Nothing to rotate, nothing to leak.

Step M4.2 — PAM: Entra PIM Mapped to CyberArk

REQUIRES PAID EXTERNAL SYSTEM — CONCEPTUAL ONLY:

CyberArk, BeyondTrust, and Delinea require paid enterprise licenses — no hands-on tenant exists. The mapping below connects each PIM concept to its PAM equivalent, covering the same conceptual ground.

Concept	Entra PIM (you built)	CyberArk (enterprise PAM)
JIT access	Eligible role + activation	Privileged access workflow / checkout
Credential vaulting	Not available	Digital Vault — no human knows the password
Session recording	Not available	Privileged Session Manager (full video)
Rotation	Not available	Auto-rotate after every use
Scope	Entra roles + Azure RBAC	Windows/Linux/DB/network — any system

AT ENTERPRISE SCALE:

Mature orgs run BOTH: Entra PIM governs the cloud identity plane, CyberArk governs the infrastructure plane, and Tier 0 credentials (Part 3 G2) are vaulted in CyberArk with session recording. This division of labour is what separates cloud-only IAM from enterprise privileged access design.

That completes the lifecycle: identity is born, provisioned, governed, verified, defended, and scaled.